UNIVERSIDAD PERUANA CAYETANO HEREDIA

FACULTAD DE CIENCIAS E INGENIERÍA

Informe
Seguridad y Gestión

SISTEMAS OPERATIVOS



Grupo 4

Integrantes:

Hernandez Lopez, Justin Brayton

Rebatta Jeri, Patricia del Pilar

Medina Rojas, Martha Sofía

Vega Sanchez. Jimena Natalia

Profesor:
Roberto Eduardo Burga Montañez

1. Seguridad y Protección amenazas y Objetivos de Seguridad

Según la norma ISO/IEC 27100 (cláusula 3.5), el ciberespacio se define como el entorno digital interconectado de redes, servicios, personas, procesos u organizaciones, incluyendo todo aquello que reside en dicho entorno o navega a través de él. Entre sus componentes fundamentales se identifican el software, los servicios de internet, las Tecnologías de la Información y la Comunicación (TIC), el Internet de las Cosas (IoE/IoT) y las personas.

- **Ciberseguridad:** la norma ISO/IEC TS 27100 (cláusula 3.2) establece que la ciberseguridad consiste en proteger a las personas, las organizaciones, la sociedad y las naciones de los riesgos cibernéticos. Salvaguardar implica mantener estos riesgos cibernéticos en un nivel tolerable.
- **Ciberdelincuencia e Impacto Económico:** conforme al Glosario de Ciberseguridad del NIST, la ciberdelincuencia abarca los delitos cometidos en internet o facilitados mediante el uso de tecnología informática. Los estudios y registros recientes muestran un incremento constante en el gasto derivado de la ciberdelincuencia proyectado progresivamente para el periodo entre 2018 y 2027.
- **Objetivos de la seguridad de la Información:** según la norma ISO/IEC 27000 (cláusula 3.28), la seguridad de la información se enfoca en la preservación de tres objetivos prioritarios:
    - Confidencialidad
    - Integridad
    - Disponibilidad

  Asimismo, se contempla la participación de propiedades adicionales como la autenticidad, la responsabilidad, el no-repudio y la fiabilidad.

2. Intentos de accesos no autorizado

- **Vulnerabilidades:**
    - **Definición:**

      Corresponde a la debilidad de un activo o control que puede ser explotada por una o varias amenazas. Las vulnerabilidades que no tienen amenazas asociadas deben monitorearse por si cambian las condiciones, y un control mal implementado puede convertirse en una vulnerabilidad.

    - **Ejemplos por Categoría:**
        - **Hardware:** Mantenimiento insuficiente o instalación defectuosa de soportes de almacenamiento, y falta de cuidado al desecharlos.
        - **Software:** Ausencia o insuficiencia de pruebas de software, e interfaz de usuario complicada.
        - **Red:** Líneas de comunicación desprotegidas y puntos únicos de falla.
        - **Personal:** Capacitación insuficiente en seguridad y trabajo no supervisado por personal externo o de limpieza.

        - **Sitio:** Red eléctrica inestable y ubicación en áreas propensas a inundaciones.
        - **Organización:** Procedimientos de supervisión ineficaces o no desarrollados, y falta de auditorías periódicas.
- **Amenazas y Agentes de Amenaza:**
    - **Amenaza:** Causa potencial de un incidente no deseado que puede provocar daño a activos, información, procesos o sistemas de una organización.
    - **Agente de amenaza:** Individuo o grupo que participa en la ejecución o respaldo de un ataque. Su evaluación requiere analizar motivaciones (religiosas, políticas, económicas), capacidades (conocimiento, financiamiento, tamaño) e intenciones (delito, diversión, espionaje).
    - **Tipos de amenazas según los activos:**
        - **Activos personales:** Robo o enmascaramiento de identidad digital, acceso no autorizado a datos financieros, robo de dinero y fraude.
        - **Activos de la organización:** Desfiguración de páginas web, ciberocupación ilegal de dominios, infiltración en reportes financieros y acceso a información confidencial.
- **Amenazas Cibernéticas Típicas y Panorama de Amenazas:**
    - **Amenazas Típicas:**
        - Ataques a través de redes (intrusión en la intranet, infección por malware, Amenaza Persistente Avanzada / APT, y Denegación de Servicio / DoS)
        - Robo de información por parte del personal, partes externas o trabajadores remotos.
        - Fallas operativas por problemas de calidad en dispositivos y sistemas TIC.
        - Fallas de gestión que impiden la aplicación eficaz de los controles de ciberseguridad.
    - **Panorama de Amenazas:** Engloba el conjunto de ciberamenazas identificadas en un contexto particular. Varía según el sector, el valor de la información poseída, el nivel de seguridad y los factores geopolíticos.
- **Relación entre Vulnerabilidad y Amenaza:**

  La existencia de una vulnerabilidad concreta permite la materialización de una amenaza:

    - Almacén desprotegido → Robo
    - Procesamiento de datos complicados → Error en la entrada de datos por el personal
    - Falta de segregación de tareas → Fraude y uso no autorizado del sistema
    - Datos no cifrados → Robo de información
    - Uso de software pirata → Infecciòn por virus
    - Sin revisión de derechos de acceso → Acceso no autorizado por antiguos empleados
    - Sin copias de respaldo → Pérdida de información
- **Impactos y Evaluación del Riesgo:**
    - **Impactos en los Pilares de Seguridad:**
        - **Confidencialidad:** Invasión de la privacidad (de usuarios o empleados) y fuga de información confidencial.

        - **Integridad:** Cambios accidentales o deliberados, resultados incorrectos o incompletos y pérdida de datos.
        - **Disponibilidad:** Degradación del desempeño, interrupción del servicio, falta de servicio e interrupción de operaciones.
    - **Riesgos para la Seguridad de la Información:** Posibilidad de que las amenazas exploten una vulnerabilidad en los activos de información causando daño a la organización. Se expresa mediante la fórmula:

      Probabilidad (de ocurrencia) x Consecuencia (impacto) = Riesgo

3. Políticas y Mecanismo de Seguridad

3.1. Mecanismos y vectores de ataque

- Vector de ataque (ISO/IEC 27032, 8.4): ruta o medio por el que un atacante accede a un equipo o servidor para entregar un resultado malicioso. Puede ser un vector único, combinado o dirigido a un blanco específico.
- Los atacantes usan múltiples vectores y los cambian con frecuencia. Por eso los defensores deben protegerse contra varios y no solo contra los ya conocidos.
- Vías de propagación: páginas web sospechosas, descargas sin verificación, correos no deseados, explotación remota, ataques de día cero y dispositivos extraíbles infectados.
- 9 vectores comunes: toma de posesión de cuentas, aplicación comprometida, ataques basados en navegadores, archivos adjuntos de correo, amenazas internas, falta de cifrado, puertos abiertos, ciberestafa (phishing) y aprovechamiento de vulnerabilidades.
- Un diagrama muestra cómo el atacante usa un vector contra las debilidades de la superficie de ataque (red, puntos finales y servidores).

3.2. Ataques internos y externos

- Internos: se originan dentro de la red, normalmente por empleados con acceso autorizado. Pueden ser intencionales o involuntarios (negligencia, poca capacitación o desatención de políticas). A veces sobrecargan la red y causan fallas.
- Externos: vienen de fuera, con phishing, DDoS y suplantación de identidad.
- Mitigación de internos (6 medidas): capacitación contra phishing, formar a empleados para reportar conductas riesgosas, comunicación entre TI y RR. HH., controles técnicos de comportamiento sospechoso, DLP (prevención de pérdida de datos) y SIEM (gestión de eventos de seguridad).
- ENISA agrupa las amenazas externas en 8 grupos: ransomware, malware, ingeniería social, amenazas contra los datos, denegación de servicio, amenazas de internet, desinformación y ataques a la cadena de suministro.

3.3. Malware

- Definición: software malicioso diseñado para dañar el sistema y su seguridad. Incluye virus, gusanos, troyanos, puertas traseras, spyware, botnets y ransomware. Puede permanecer sin ser detectado y persistente por tiempo indefinido.
- Tendencias (ENISA 2022):
    - Fuerte aumento tras la pandemia, por cryptojacking y malware de IoT (casi se duplicó en el primer semestre de 2022, con las botnets Mirai y Mozi).
    - Crecen los ataques a la cadena de suministro de código abierto, como

bibliotecas maliciosas en NPM, Python y RubyGems mediante typo-squatting.
    - Se dejaron las macros de Office para usar archivos contenedores (ISO, ZIP, RAR) y accesos directos LNK.
    - El malware móvil sigue activo, con ataques dirigidos como Pegasus y Predator.
- Mitigación (9 medidas): plan de respuesta a incidentes, gestión de parches y vulnerabilidades, acceso remoto seguro y gestión de privilegios, concientización, intercambio de información con pares y CERT, supervisión de registros, EDR/XDR e inspección de tráfico, detección multicanal e inventario de activos.

3.4. Ransomware

- Definición: malware que exige un rescate, hoy en criptomoneda, para devolver el acceso a datos y sistemas. Suele entrar mediante otro malware, como troyanos.
- Fue la principal amenaza de ciberseguridad en la UE en 2021 y su objetivo principal es el ransomware público.
- Estadísticas:
    - Al menos el 15.45 % de los usuarios de internet se encontró con malware en 2021.
    - El ransomware causó cerca del 20 % de las violaciones en 2022.
    - Hubo unos 236.1 millones de ataques en el primer semestre de 2022.
    - Se identificaron más de 130 familias, y Gandcrab fue la más prevalente.
- Mitigación (10 medidas): copias de seguridad seguras, plan de respuesta, seguridad de la infraestructura orientada a internet, controles de acceso, concientización, colaboración con pares y CERT, supervisión centralizada de registros, gestión de activos, seguridad de dispositivos finales y filtrado de correo.

3.5. Ingeniería social

- Explota el comportamiento o los errores humanos para obtener información o accesos, por ejemplo haciendo que el usuario abra archivos, visite sitios o dé acceso no autorizado.
- Vectores: phishing, spear phishing, whaling, smishing, vishing, ataque al correo empresarial, fraude, suplantación y falsificación.
- Mitigación (9 medidas): actualizar la huella digital, designar una función OSINT, registrar dominios parecidos al de la organización, capacitar según las nuevas tendencias, vigilar dominios y certificados, usar inteligencia de amenazas y suscribirse a alertas de violaciones de datos.

3.6. Amenazas contra los datos

- Buscan acceder a los datos, revelarlos o manipularlos. Se clasifican en:
    - Violación de seguridad: ataque intencional para obtener datos sensibles sin autorización.
    - Fuga o filtración: exposición involuntaria por fallas técnicas, vulnerabilidades o errores humanos.
- Con ML e IA crece el riesgo de manipulación y envenenamiento de datos, que compromete la precisión de los resultados.
- Causas de las violaciones (gráfico): el 24 % se atribuyó a fallos de TI y el 21 % a errores humanos. El resto se reparte entre ataques destructivos, a la cadena de suministro, ransomware y otros.
- Mitigación (7 pasos): equipo de respuesta y descubrimiento de activos, presupuestos

eficaces, estrategia integral de ciberseguridad, auditorías de datos, saneamiento y contramedidas contra el envenenamiento y el aprendizaje automático adversarial, prevención de pérdida de datos y copias de seguridad con recuperación.

3.7. Amenazas contra la disponibilidad

- Denegación de servicio (DDoS): ataca la disponibilidad al sobrecargar el servicio, sus recursos y la infraestructura de red, de modo que los usuarios no pueden acceder.
- Amenazas de internet: destrucción física de la infraestructura, supresión activa de información, autoridades de certificación controladas por gobiernos y secuestro de BGP.
- Mitigación: equipo especializado en DDoS, validar acuerdos con terceros, plan de contingencia para restaurar el servicio, evaluación de riesgos y activos, buenas prácticas de red (políticas de acceso y filtrado de tráfico) y parches en todos los sistemas.

3.8. Desinformación e información errónea

- Difusión de información falsa para engañar o manipular a personas u organizaciones. La IA y la nube facilitan fabricar contenido malicioso.
- Mitigación (11 medidas): leyes y reglamentaciones, capacitación, información mediática de alta calidad, alfabetización mediática, desacreditar historias falsas, uso de IA, prácticas resilientes de recolección y distribución, validación de fuentes, vigilancia de la red, certificación de contenidos y herramientas de detección en redes sociales.

Preguntas

¿Qué nos llevamos?

Que las amenazas llegan por muchos frentes a la vez (técnicos y humanos) y que cada amenaza se ataca con una combinación de medidas: copias de seguridad, parches, controles de acceso, monitoreo y, sobre todo, capacitación. También que el eslabón humano aparece en casi todo: ingeniería social, ataques internos y el 21 % de las violaciones por error humano.

¿Qué habilidades o conocimientos desarrollamos?

- Reconocer los principales vectores de ataque y la diferencia entre ataques internos y externos.
- Identificar las 8 familias de amenazas de ENISA y relacionarlas con la tríada CID: datos (confidencialidad e integridad) y DDoS (disponibilidad).
- Distinguir malware, ransomware e ingeniería social, con sus técnicas más comunes.
- Distinguir una violación de datos de una fuga y entender el riesgo del envenenamiento de datos en sistemas de IA.
- Proponer medidas de mitigación para cada amenaza.
- Conocer herramientas y conceptos como SIEM, DLP, EDR/XDR, CERT y OSINT.

¿Dónde lo podemos aplicar?

- Administración de sistemas: copias de seguridad, parches, registros y control de privilegios.
- Desarrollo de software: revisar dependencias de NPM y Python para evitar bibliotecas maliciosas, y proteger datos de entrenamiento en proyectos de ML.

- Empresas y universidades: campañas de concientización contra phishing, planes de respuesta a incidentes y de contingencia ante DDoS.
- Vida personal: desconfiar de correos y enlaces sospechosos, no descargar archivos sin verificar, activar la verificación en dos pasos y contrastar información antes de compartirla.

¿Cómo podemos mejorar lo adquirido?

- Leer el informe ENISA Threat Landscape completo y comparar con ediciones más recientes.
- Analizar casos reales de ransomware o filtraciones e identificar el vector, el impacto y la medida que faltó.
- Armar una tabla propia de amenaza, vector, impacto y mitigación para un proyecto del curso.
- Practicar con simulaciones de phishing educativas y laboratorios autorizados.
- Profundizar en SIEM y detección de intrusiones en una máquina virtual propia.

¿Qué es lo que más me entusiasma del tema?
Me llama la atención lo rápido que cambia el panorama: los atacantes abandonaron técnicas (como las macros de Office) y adoptan otras apenas se bloquean. También me interesa la seguridad de los datos en la IA: el envenenamiento y la manipulación de datos muestran que un modelo es tan confiable como los datos que lo alimentan, algo muy relevante para proyectos de machine learning.

4. Validación

Cómo implementar controles de seguridad concretos (ISO/IEC 27032, NIST SP 800-52/53/128/133, ISO 27002). Los temas son seguridad de aplicaciones, criptografía, gestión de vulnerabilidades, gestión de cambios y configuración, malware y control de accesos.

4.1. Seguridad de aplicaciones

- La seguridad debe integrarse desde el diseño y revisarse periódicamente frente a nuevas amenazas. Se recomienda un ciclo de vida de desarrollo seguro que incluya modelado de amenazas, autenticación, control de sesiones, validación de datos y revisión de diseño.
- Principios de ingeniería de seguridad (NIST SA-8): protección por capas, políticas de seguridad y privacidad, arquitectura, controles como base del diseño, requisitos en todo el ciclo de vida, límites físicos y lógicos, capacitación de desarrolladores, modelos de amenazas y agentes de amenaza.
- Controles de aplicaciones: autenticación, autorización, cifrado, registros de eventos y pruebas de seguridad.
- Pruebas de seguridad (AST) por etapa: SAST y SCA (desarrollo), DAST y MAST (aceptación y preproducción), IAST (preproducción) y RASP (producción).
- Revisión de código seguro (5 pasos): definir objetivos, análisis preliminar, revisar el código, examinar la arquitectura y hacer pruebas de penetración.
- También se ven un ejemplo de ataque con secuencia de comandos (código malicioso que vuelve a la página web), el flujo de un servicio de autenticación con token y reglas para restringir sitios web inapropiados (por ejemplo, bloqueando IP o dominio).

4.2. Controles criptográficos

- La criptografía protege confidencialidad, integridad, autenticación y no repudio. La solución depende del objetivo de la organización.
- El nivel de cifrado viene de la clave, no del secreto del algoritmo.

	Simétrica	Asimétrica
Claves	Una sola	Dos (pública y privada)
Velocidad	Muy rápida	Hasta 10,000 veces más lenta
Uso	Grandes volúmenes de datos	Distribución de claves
Ofrece	Confidencialidad e integridad	Confidencialidad, autenticidad y no repudio
Debilidad	Distribución segura de la clave	Necesita claves más grandes

- Sistemas híbridos: combinan la comodidad de la asimétrica con la eficiencia de la simétrica. VPN y HTTPS son ejemplos.
- Gestión de claves (ISO 27002, 8.24): generación automatizada y aleatoria, distribución por un canal seguro, almacenamiento dentro del sistema criptográfico, archivado, recuperación, revocación, destrucción y auditoría. NIST SP 800-133 recomienda generar claves con un generador de bits aleatorios dentro de un módulo FIPS 140.

4.3. Gestión de vulnerabilidades

- Proceso de 4 componentes: identificación, evaluación (con CVSS), solución (parches, actualizaciones) y notificación (registros e informes).
- Escala CVSS: ninguna 0.0, baja 0.1–3.9, media 4.0–6.9, alta 7.0–8.9, crítica 9.0–10.0.
- Otras mitigaciones: cambiar prácticas operativas, reconfigurar sistemas, capacitar al personal, defensa en profundidad y pruebas de parches antes de implementar.
- La vulnerabilidad técnica son fallas en el SO o software. La evaluación puede ser interna (con acceso a la red) o externa (sin acceso). Incluso se pueden usar programas de recompensas por hallar errores.

4.4. Gestión de configuración y cambios

Configuración (NIST 800-128), 4 fases: planificación, identificar e implementar configuraciones, controlar los cambios y seguimiento.

- Instalación de software en SO: los usuarios no deben tener permiso para instalar; solo se instala de fuentes confiables y con aprobación previa.
- Gestión de cambios: evita cambios no programados, corrupción o pérdida de datos. Se planifica con comunicación a las partes interesadas, sin implementar varios procesos a la vez y con capacitación.
- Proceso: enviar la solicitud, revisarla (aprobar o rechazar), coordinar, implementar y medir resultados (revisión posterior y auditoría).

- Dispositivos finales: son más críticos porque salen del perímetro de la organización.

4.5. Controles contra malware

Antimalware en puertas de enlace y en todos los clientes, escaneo de archivos, correos y enlaces, bloqueo de sitios sospechosos, concientización de usuarios, parches según criticidad y planes de recuperación con copias de seguridad.

- Medidas:
    - Prevención: firewall, cifrado, segregación de tareas, políticas y barreras físicas.
    - Detección: antivirus, sistemas de detección de intrusiones y supervisión de registros.
    - Corrección: eliminar código malicioso, planes de continuidad y prevención de intrusiones en el host.
- Se refuerza con autenticación robusta (contraseña más tarjeta, biometría o token) y certificados de CA reconocidas.

4.6. Control de accesos

- Los derechos de acceso aplican también a dispositivos, aplicaciones y procesos. Cada conexión debe autenticarse, cada actividad debe estar autorizada según roles y cada entidad debe tener mínimos privilegios.
- NIST PR.AC: gestión de identidades y credenciales (AC-1), acceso físico (AC-2) y remoto (AC-3), permisos con mínimo privilegio y separación de funciones (AC-4) y segmentación de la red (AC-5).

Preguntas

¿Qué habilidades o conocimientos desarrollamos?

- Distinguir criptografía simétrica, asimétrica e híbrida, y saber cuándo usar cada una.
- Entender el ciclo de vida de una clave: generar, distribuir, almacenar, archivar y destruir.
- Evaluar vulnerabilidades con CVSS y priorizar su corrección.
- Aplicar el principio de mínimo privilegio y la separación de funciones en el control de accesos.
- Reconocer qué prueba de seguridad (SAST, DAST, RASP, etc.) corresponde a cada etapa del desarrollo.
- Clasificar controles contra malware en prevención, detección y corrección.
- **Seguir un proceso formal de gestión de cambios y de configuración.**

¿Dónde lo podemos aplicar?

- Administración de sistemas operativos: crear usuarios, asignar permisos (chmod/chown) y restringir la instalación de software.
- Desarrollo de software: autenticación con tokens, cifrado de datos sensibles, pruebas de seguridad en el pipeline y revisión de código.
- Servicios web y nube: HTTPS, VPN y gestión de certificados.
- Empresas: parchado periódico, gestión de cambios, antimalware y auditorías.
- Vida personal: contraseñas fuertes con segundo factor, actualizaciones al día, instalar solo desde fuentes confiables y respaldos.

¿Cómo podemos mejorar lo adquirido?

- Practicar en un entorno controlado (una máquina virtual propia): permisos, usuarios, firewall y cifrado de archivos.
- Probar herramientas de análisis de vulnerabilidades y de código en proyectos propios, sin atacar sistemas ajenos.
- Implementar un ejemplo híbrido: cifrar un archivo con clave simétrica y proteger esa clave con un par asimétrico.
- Leer los controles originales (ISO 27002 y NIST SP 800-53) y practicar con puntajes CVSS reales.
- Ir hacia certificaciones introductorias como Security.

¿Qué es lo que más me entusiasma del tema?

Me entusiasma que la seguridad se construye en capas y combina ingeniería con gestión. Un buen diseño de cifrado no sirve si la clave se almacena mal; por eso el ciclo de vida de las claves y la defensa en profundidad resultan tan interesantes. También me atrae que sea aplicable a cualquier proyecto, desde una app web hasta un sistema de IA, donde proteger datos y accesos es parte del diseño y no un añadido final.

5. Protección y Control de Acceso

La protección y el control de acceso comprenden los mecanismos utilizados para garantizar que únicamente los usuarios autorizados puedan acceder a los recursos de un sistema. Su aplicación permite proteger la información, establecer permisos y supervisar las actividades realizadas.

5.1. Mecanismos de Control de Acceso

Los sistemas de control de acceso se fundamentan en cuatro mecanismos principales:

- **Identificación:** proceso mediante el cual un usuario declara su identidad utilizando un identificador único, como un nombre de usuario.
- **Autenticación:** procedimiento que permite verificar la identidad del usuario mediante credenciales o características personales.
- **Autorización:** determina los recursos y operaciones a los que puede acceder un usuario previamente identificado y autenticado.
- **Rendición de cuentas:** permite registrar y supervisar las actividades realizadas por los usuarios para establecer responsabilidades.

5.2. Métodos de Autenticación

La autenticación puede realizarse mediante tres factores principales:

- **Algo que la persona conoce:** contraseñas, PIN o respuestas a preguntas de seguridad. Es un método sencillo, pero vulnerable al robo de credenciales.
- **Algo que la persona posee:** tarjetas inteligentes, dispositivos físicos o tokens de seguridad. Proporciona mayor protección, aunque requiere administrar los dispositivos.
- **Algo que la persona es:** características biométricas, como huellas digitales,

reconocimiento facial, iris y voz.

La autenticación robusta combina diferentes factores para incrementar la seguridad y reducir el riesgo de accesos no autorizados.

Gestión de contraseñas: se recomienda utilizar contraseñas largas, complejas y fáciles de recordar, evitando combinaciones comunes y el uso de información personal.

Otros mecanismos de autenticación:

- **VPN (Red Privada Virtual):** permite establecer conexiones seguras para el acceso remoto mediante túneles de comunicación.
- **SSO (Inicio de Sesión Único):** permite acceder a múltiples aplicaciones utilizando una sola autenticación.
- **Tokens de seguridad:** permiten verificar la identidad del usuario mediante dispositivos o códigos de autenticación.

5.3. Autorización y Matriz de Control de Acceso

La autorización establece los permisos que posee cada usuario sobre los recursos del sistema.

- **Revisión de derechos de acceso:** consiste en verificar periódicamente los permisos asignados, especialmente cuando existen cambios de funciones o salida de empleados.
- **Principio de mínimo privilegio:** cada usuario debe disponer únicamente de los permisos necesarios para cumplir sus responsabilidades.
- **Matriz de control de acceso:** modelo de seguridad que relaciona los sujetos con los objetos del sistema y especifica las operaciones permitidas, como lectura, escritura o ejecución.
- **Listas de control de acceso (ACL):** establecen qué usuarios pueden acceder a determinados recursos.
- **Listas de capacidades:** especifican los recursos y operaciones autorizadas para cada sujeto.

5.4. Gestión y Protección de Redes

Según la norma ISO/IEC 27032, la gestión de redes debe implementar controles que permitan mantener la seguridad y disponibilidad de los servicios.

- **Gestión de redes:** consiste en administrar los dispositivos, conexiones y recursos para garantizar su funcionamiento seguro.
- **Segmentación de redes:** permite separar diferentes áreas de comunicación y limitar el acceso entre ellas.
- **Monitoreo de tráfico:** facilita identificar actividades sospechosas y problemas de funcionamiento.

Herramientas de supervisión:

- **Wireshark:** permite capturar y analizar paquetes de red para identificar problemas de comunicación.
- **Microsoft Network Monitor:** herramienta utilizada para examinar el tráfico y diagnosticar problemas de red.

- **Colasoft Capsa:** permite analizar el rendimiento y supervisar las actividades de una red.

5.5. Protección de la Privacidad y la Información

La protección de la información personal busca impedir su divulgación, modificación o utilización sin autorización.

- **Protección de la Información de Identificación Personal (IIP):** según NIST SP 800-122, requiere identificar los datos personales, evaluar su sensibilidad y aplicar controles adecuados.
- **Eliminación de información:** según ISO/IEC 27002, cláusula 8.10, los datos que ya no sean necesarios deben eliminarse de manera segura.
- **Anonimización:** proceso mediante el cual se eliminan los elementos que permiten identificar a una persona.
- **Seudonimización:** reemplaza los identificadores personales por códigos o referencias, conservando información adicional por separado que permitiría recuperar la identidad.
- **Prevención de Fugas de Datos (DLP):** utiliza políticas y controles para evitar la divulgación no autorizada de información confidencial.

5.6. Copias de Seguridad de la Información

Según ISO/IEC 27002, las copias de seguridad permiten conservar y recuperar la información frente a pérdidas, fallas técnicas o incidentes de seguridad.

Tipos de copias de seguridad:

- **Completa:** almacena todos los datos seleccionados y facilita la recuperación total.
- **Diferencial:** guarda los cambios realizados desde la última copia completa.
- **Incremental:** almacena únicamente los cambios producidos desde la última copia de seguridad realizada.

La organización debe establecer procedimientos de respaldo, periodos de conservación, medios de almacenamiento seguros y pruebas periódicas de recuperación.

Asimismo, las copias pueden comprender información, software y sistemas, incluyendo servicios almacenados en la nube.

5.7. Externalización de TI y Computación en la Nube

- **Externalización de TI:** consiste en contratar proveedores externos para realizar actividades tecnológicas como mantenimiento, administración de redes, bases de datos y soporte técnico.
- **Gestión de servicios externalizados:** requiere establecer requisitos de seguridad, definir responsabilidades, supervisar los servicios y verificar el cumplimiento de los acuerdos.

Computación en la nube: según NIST SP 800-145, permite acceder a recursos informáticos compartidos mediante una red, con disponibilidad y capacidad de adaptación según las necesidades.

Sus características principales son el autoservicio bajo demanda, acceso amplio a la red, agrupación de recursos, elasticidad rápida y servicio medido.

Modelos de servicios en la nube:

- **IaaS (Infraestructura como Servicio):** proporciona recursos de infraestructura, como servidores, almacenamiento y redes.
- **PaaS (Plataforma como Servicio):** ofrece entornos y herramientas para desarrollar e implementar aplicaciones.
- **SaaS (Software como Servicio):** proporciona aplicaciones accesibles mediante internet.
- **UCaaS (Comunicaciones Unificadas como Servicio):** integra servicios de comunicación y colaboración, como mensajería, llamadas y videoconferencias.

6. Modelos Formales de Protección

Los modelos de protección permiten representar y organizar los mecanismos de seguridad utilizados para controlar los recursos y gestionar los riesgos de una organización.

6.1. Modelos de Servicios en la Nube

Los modelos de servicios en la nube presentan diferentes niveles de administración y responsabilidad sobre los recursos tecnológicos.

- **TI tradicional:** la organización administra las aplicaciones, datos, sistemas operativos, servidores, almacenamiento y redes.
- **IaaS:** el proveedor administra la infraestructura física y la virtualización, mientras que el cliente conserva mayor responsabilidad sobre el sistema operativo, las aplicaciones y los datos.
- **PaaS:** el proveedor administra la infraestructura y la plataforma, permitiendo que el cliente se concentre en las aplicaciones y sus datos.
- **UCaaS:** proporciona servicios de comunicación administrados mediante una infraestructura en la nube.
- **SaaS:** el proveedor administra la aplicación y la infraestructura necesaria para su funcionamiento, mientras el cliente utiliza el servicio.

La elección del modelo determina la distribución de responsabilidades de seguridad entre el proveedor y la organización.

6.2. Proceso de Gestión de Riesgos

Según ISO/IEC 27005, la gestión de riesgos de seguridad de la información es un proceso sistemático destinado a identificar, analizar, evaluar y tratar los riesgos que pueden afectar a una organización.

Etapas principales:

- **Establecimiento del contexto:** determina el alcance, los objetivos y los criterios utilizados para evaluar los riesgos.
- **Identificación de riesgos:** reconoce los activos, amenazas y vulnerabilidades que

pueden afectar la seguridad.

- **Análisis de riesgos:** estima la probabilidad de ocurrencia y las consecuencias de los incidentes.
- **Evaluación de riesgos:** compara los resultados del análisis con los criterios establecidos para determinar su importancia.
- **Tratamiento de riesgos:** selecciona e implementa medidas para reducir, evitar, compartir o aceptar los riesgos.
- **Aceptación del riesgo:** determina si el nivel de riesgo residual puede ser asumido por la organización.
- **Comunicación y consulta:** permite compartir información sobre los riesgos y las decisiones tomadas.
- **Seguimiento y revisión:** supervisa los riesgos identificados y verifica la eficacia de los controles establecidos.

La gestión de riesgos es un proceso continuo que permite mejorar las decisiones de seguridad y mantener la protección de los activos de información.

7. Retroalimentación

Reflexión final:

1. ¿Qué nos llevamos?

Se adquirieron conocimientos sobre la importancia de la seguridad de la información en los sistemas operativos, comprendiendo los mecanismos de protección, control de acceso, autenticación y autorización. Asimismo, se reconoció la importancia de aplicar políticas de seguridad y gestionar los riesgos para garantizar la confidencialidad, integridad y disponibilidad de la información.

2. ¿Qué habilidades o conocimientos desarrollamos?

Se desarrollaron conocimientos relacionados con la identificación de amenazas y vulnerabilidades, la implementación de mecanismos de autenticación y la administración de permisos de acceso. Además, se comprendieron los modelos de servicios en la nube, los procedimientos de respaldo de información y las etapas de gestión de riesgos de seguridad.

3. ¿Dónde lo podemos aplicar?

Estos conocimientos pueden aplicarse en la administración de sistemas operativos, redes empresariales, servidores y plataformas de almacenamiento en la nube. También permiten implementar medidas de protección de datos, gestionar los permisos de usuarios y prevenir accesos no autorizados en entornos personales y organizacionales.

4. ¿Cómo podemos mejorar lo adquirido?

Se pueden reforzar los conocimientos mediante la realización de prácticas relacionadas con la configuración de permisos, implementación de controles de acceso, administración de copias de seguridad y análisis de vulnerabilidades. Asimismo, es importante mantenerse actualizado sobre las nuevas amenazas cibernéticas, herramientas de seguridad y normas internacionales de protección de la información.

5. ¿Qué es lo que más me entusiasma del tema?

Lo más interesante del tema es comprender cómo los sistemas operativos implementan diferentes mecanismos para proteger la información y prevenir amenazas informáticas. Asimismo, resulta importante conocer cómo se aplican estos conocimientos en situaciones reales, permitiendo desarrollar soluciones que contribuyan a mejorar la seguridad y confiabilidad de los sistemas informáticos.